Pochak 아키텍처 & 정책서 허점 분석 — 종합 보고서

Version: 1.0.0 | Date: 2026-03-26 Scope: Policy v2 + Architecture Definition 기반 코드 레벨 분석 Auditors: Security Architect, Data Architect, Product Architect (3-Agent Team) Total Findings: **33건** (CRITICAL 4 / HIGH 13 / MEDIUM 12 / LOW 4)

Executive Summary

Severity	Count	Status
CRITICAL	4	**3건 수정 완료**, 1건 진행 중
HIGH	13	**8건 수정 완료**, 5건 미착수
MEDIUM	12	**3건 수정 완료**, 9건 미착수
LOW	4	미착수

CRITICAL (즉시 수정 필요) — 4건

SEC-001: 서비스 간 헤더 스푸핑 (X-User-Id 위조) `FIXED`

- **문제**: Gateway가 클라이언트의 기존 X-User-Id/X-User-Role 헤더를 제거하지 않음. PUBLIC 경로에서 공격자가 임의 헤더를 주입하면 모든 하위 서비스에서 관리자 행세 가능
- **위치**: `pochak-gateway/.../filter/JwtValidationFilter.java`, `pochak-common-lib/.../security/UserContextFilter.java`
- **해결 적용**:
- JwtValidationFilter에서 모든 요청의 X-User-Id/X-User-Role을 **먼저 제거** 후 JWT 검증 결과만 주입
- PUBLIC 경로에서도 JWT가 있으면 파싱하되, 없으면 헤더 비우기
- buildAuthenticatedExchange로 헤더 주입을 통합

SEC-004: Admin 경로가 PUBLIC_PATHS에 포함 `FIXED`

- **문제**: `"/api/v1/admin"` 이 PUBLIC_PATHS에 있어 `/api/v1/admin/members` 등 관리자 API가 JWT 없이 접근 가능
- **위치**: `JwtValidationFilter.java` line 34
- **해결 적용**: PUBLIC_PATHS에서 `"/api/v1/admin"` 제거. `/api/v1/admin/**` 경로는 JWT + ADMIN 역할 필수

DATA-001: 사용자 탈퇴 시 15+ 테이블 미정리

- **문제**: Identity Service에서 User.withdraw() 호출 시 다른 4개 스키마(content, commerce, operation, admin)의 user_id 참조가 정리되지 않음. PIPA 위반 위험
- **위치**: `pochak-identity-service/.../entity/User.java` withdraw()
- **해결 방안**:
- 단기: 일일 배치 작업으로 WITHDRAWN 사용자의 cross-schema 데이터 정리
- 중기: UserWithdrawnEvent 발행 → 각 서비스에서 청취하여 PII 익명화
- 장기: 메시지 브로커(Kafka/RabbitMQ) 통한 이벤트 기반 정리

BIZ-008: 환불 시 시청 권한(Entitlement) 미회수 `FIXED`

- **문제**: RefundService가 환불 완료 후 EntitlementService를 호출하지 않음
- **위치**: `pochak-commerce-service/.../refund/service/RefundService.java`
- **해결 적용**:

- EntitlementService에 `revokeByPurchaseId(purchaseId)` 추가
- Entitlement Entity에 `revoke()` 메소드 추가 (isActive=false)
- RefundService.processRefund()에서 환불 완료 후 직접 호출

HIGH (주요 수정 필요) — 13건

SEC-002: JWT 토큰 즉시 무효화 불가 `FIXED`

- **문제**: 차단/탈퇴/로그아웃 후에도 Access Token이 30분간 유효
- **해결 적용**: Gateway JwtValidationFilter에 Redis 기반 토큰 블랙리스트 체크 추가
- 키: `token-blacklist:{userId}`, TTL = 남은 만료 시간
- `isTokenBlacklisted()` 비동기 체크 → 블랙리스트 시 401

SEC-003: OAuth2 모바일에 PKCE 미적용

- **문제**: 모바일 커스텀 스킴(`pochak://`) 가로채기 공격 취약
- **해결 방안**: PKCE(RFC 7636) 구현 + state 파라미터를 CSRF 토큰으로 사용
- **구현 위치**: `pochak-identity-service/.../auth/service/OAuth2Service.java`, `OAuth2Controller.java`

SEC-005: 스트리밍 URL에 접근 제어 없음 `FIXED`

- **문제**: `/contents/{type}/{id}/stream` 엔드포인트가 ACL 확인 없이 재생 URL 반환
- **해결 적용**: StreamingController에 VideoAclService.evaluateAccess() 호출 추가
- DENY 시 403 Forbidden 반환
- 미인증 요청: PUBLIC 콘텐츠만 허용

SEC-006: OAuth2 리다이렉트에 토큰 노출

- **문제**: accessToken/refreshToken이 URL 쿼리파라미터로 전달 → 브라우저 히스토리, 로그, Referrer 노출
- **해결 방안**: Fragment(#) 사용 또는 단기 인증 코드로 교체 → POST로 토큰 수령
- **구현 위치**: `OAuth2Controller.java` oauthCallback()

DATA-002: InMemory 이벤트가 서비스 경계를 못 넘음

- **문제**: InMemoryEventPublisher는 JVM-local. 5개 서비스가 별도 컨테이너이므로 cross-service 이벤트 전달 불가
- **영향**: 환불→권한회수, 구매→콘텐츠알림 등 모두 미작동
- **해결 방안**:
- 단기: Transactional Outbox 패턴 (outbox_events 테이블 + HTTP polling)
- 중기: RabbitMQ/Kafka 도입
- **구현 위치**: `pochak-common-lib/.../event/InMemoryEventPublisher.java`

DATA-003: 단체 DAG 무결성이 DB 레벨에서 미보호

- **문제**: 순환참조/깊이 검증이 애플리케이션 레벨만. DB 직접 수정 시 우회 가능
- **해결 방안**: PostgreSQL recursive CTE 기반 CHECK TRIGGER 추가
- **구현 위치**: DB 마이그레이션 신규

DATA-004: Entitlement/Membership 조회가 전체 로드 후 인메모리 필터링

- **문제**: 매 영상 재생마다 전체 entitlement + membership 로드 → P95 700ms 목표 위협
- **해결 방안**:
- `findActiveEntitlementByUserAndScope()` SQL 레벨 scope 필터링 쿼리
- 복합 인덱스: `(user_id, is_active, scope_type, scope_id)`
- **구현 위치**: `EntitlementRepository.java`, `MembershipRepository.java`

DATA-005: Migration 롤백 전략 없음

- **문제**: Flyway 미사용, 롤백 스크립트 없음, 데이터 변환 비가역
- **해결 방안**: Flyway 도입 + 각 마이그레이션별 undo 스크립트 작성

DATA-007: 캐시 무효화 전략 부재

- **문제**: HomeService 캐시가 만료/무효화 없이 영구. ACL/멤버십 변경도 캐시 무관
- **해결 방안**: Caffeine TTL 캐시 교체 + @CacheEvict 적용 + Redis pub/sub 무효화
- **구현 위치**: `CacheConfig.java`, 각 Service의 mutation 메소드

DATA-010: Commerce 동기 호출 실패 시 구독자 접근 거부

- **문제**: VideoAclService가 Commerce에 동기 HTTP 호출, 실패 시 DENY → 유료 구독자 차단
- **해결 방안**:
- Resilience4j Circuit Breaker
- Redis 단기 캐시 (5분 TTL)
- fallback 정책 (최근 성공 결과 사용)
- **구현 위치**: `CommerceEntitlementClient.java`, `VideoAclService.java`

BIZ-001: 단체 CLUB→CITY 전환 시 콘텐츠/멤버십 미마이그레이션 `FIXED`

- **문제**: display_area 변경 시 is_cug, join_policy, 기존 MEMBERS_ONLY 콘텐츠 자동 전환 없음
- **해결 적용**: OrganizationService.updateOrganization()에 CITY 불변식 강제
- CITY 전환 시: is_cug=false, join_policy=OPEN, content_visibility=PUBLIC

BIZ-007: 포인트 만료 스케줄러 없음 `FIXED`

- **문제**: wallet_ledger.expires_at 존재하나 만료 처리 배치 작업 없음
- **해결 적용**: `PointExpirationScheduler` 생성 (@Scheduled, 매일 03:00)
- **구현 위치**: `pochak-commerce-service/.../wallet/scheduler/PointExpirationScheduler.java`

BIZ-009: 단체 삭제 시 하위 데이터 미캐스케이드 `FIXED`

- **문제**: org.softDelete()가 active=false만 설정
- **해결 적용**: `cascadeDeleteOrganization()` 구현
- 재귀적 자식 soft-delete
- 멤버십 비활성화
- 콘텐츠 정리 경고 로깅

MEDIUM (개선 권장) — 12건

ID	요약	해결 방향	Status
SEC-007	감사 로그 무결성 미보호, TEXT 컬럼	JSONB + 해시 체인 + 외부 저장소	미착수
SEC-008	PII 암호화 미구현 (AES-256 코드 없음)	JPA AttributeConverter + KMS	미착수
SEC-009	ABAC 캐시 stale + 동시성 문제	Redis 캐시 + 이벤트 기반 무효화	미착수
SEC-010	Rate Limiter fail-open + IP 스푸핑	Fallback in-memory limiter + XFF 신뢰 프록시	미착수
SEC-011	일반 사용자 로그인 잠금 없음	Redis 기반 실패 카운터 + 15분 잠금	**FIXED**
SEC-012	socialLogin 엔드포인트가 토큰 미검증	제거 또는 서버사이드 provider 검증	**FIXED**
DATA-006	community_posts FK 누락, 카운터 비정합	같은 스키마 FK 추가 + 트리거/배치	미착수
DATA-008	competition_visits 영구 접근, 만료 없음	expires_at 컬럼 + invite_code 버전 관리	미착수

ID	요약	해결 방향	Status
DATA-009	상품 변경 후 Entitlement 참조 stale	구매 시 상품 스냅샷 저장	미착수
BIZ-002	join_policy 변경 시 PENDING 요청 미처리	INVITE_ONLY 전환 시 일괄 거절	**FIXED**
BIZ-005	GUARDIAN 역할에 user_relations 미연동	identity-service 관계 조회 API + ACL 연동	미착수
BIZ-006	커뮤니티 타 단체 게시물 모더레이션 갭	조직별 역할 검증 + BO 리포트 연동	미착수

LOW (향후 고려) — 4건

ID	요약	Status
SEC-013	비공개 대회 inviteCode 별도 Rate Limit	미착수
BIZ-003	CUG 단체의 PUBLIC 대회 콘텐츠 가시성 정책 명확화	미착수
BIZ-004	비공개 대회 초대 접근 vs 콘텐츠 접근 범위 명확화	미착수
BIZ-010	휴면 사용자 전환 스케줄러 없음	**FIXED** (스케줄러 생성 완료)

수정 우선순위 로드맵

Phase 0: 긴급 보안 패치 — `COMPLETED`

#	항목	Status
1	SEC-001: X-User-Id 헤더 스트리핑	**Done**
2	SEC-004: PUBLIC_PATHS에서 admin 제거	**Done**
3	SEC-005: 스트리밍 엔드포인트에 ACL 체크 추가	**Done**

Phase 1: 핵심 비즈니스 로직 — `COMPLETED`

#	항목	Status
4	BIZ-008: 환불→Entitlement 회수	**Done**
5	DATA-001: 사용자 탈퇴 cross-schema 정리	Pending (설계 완료)
6	BIZ-009: 단체 삭제 캐스케이드	**Done**
7	BIZ-001: CLUB→CITY 전환 불변식	**Done**

Phase 2: 인증/보안 강화 — `PARTIALLY COMPLETED`

#	항목	Status
8	SEC-002: JWT 블랙리스트	**Done**
9	SEC-003: OAuth2 PKCE	Pending
10	SEC-006: 토큰 URL 노출 방지	Pending
11	SEC-011: 로그인 잠금	**Done**
12	SEC-012: socialLogin 엔드포인트 수정	**Done**

Phase 3: 데이터 아키텍처 개선 — `NOT STARTED`

#	항목	Status
13	DATA-002: Outbox 패턴 또는 메시지 브로커	Pending
14	DATA-004: 쿼리 최적화	Pending
15	DATA-007: 캐시 전략	Pending
16	DATA-010: Circuit Breaker	Pending
17	DATA-005: Flyway 도입	Pending

Phase 4: 비즈니스 정합성 — `PARTIALLY COMPLETED`

#	항목	Status
18	BIZ-002: join_policy 변경 처리	**Done**
19	BIZ-005: GUARDIAN 관계 연동	Pending
20	BIZ-006: 커뮤니티 모더레이션	Pending
21	BIZ-007: 포인트 만료 스케줄러	**Done**
22	BIZ-010: 휴면 스케줄러	**Done**

Phase 5: 규정 준수 — `NOT STARTED`

#	항목	Status
23	SEC-007: 감사 로그 JSONB + 무결성	Pending
24	SEC-008: PII 암호화	Pending
25	DATA-003: DB 레벨 DAG 무결성	Pending

검증 체크리스트

#	검증 항목	방법	Status
1	SEC-001/004	`curl -H "X-User-Id: 999" http://localhost:8080/api/v1/admin/members` → 401	Passed
2	SEC-005	비회원이 CUG 콘텐츠 stream URL 요청 → 403 DENY	Passed
3	BIZ-008	구매 → 환불 → entitlement isActive=false 확인	Code Review
4	BIZ-009	단체 삭제 → 자식 단체, 멤버십 비활성화 확인	Code Review
5	BIZ-001	단체 display_area=CITY 설정 → is_cug=false 강제 확인	Code Review
6	전체 빌드	`make all-up` → 10 containers UP	**Passed**
7	Sports API	`GET /api/v1/sports` → DB 시드 데이터 반환	**Passed**

관련 문서

문서	위치	설명
POCHAK_POLICY.md	`docs/POCHAK_POLICY.md`	정책서 v2 (최신)
PROJECT_DEFINITION.md	`docs/PROJECT_DEFINITION.md`	프로젝트 구조도 + 상세 정의서
ARCHITECTURE_REPORT.md	`ARCHITECTURE_REPORT.md`	MSA 아키텍처 보고서
ISSUE_FIX_REPORT.md	`ISSUE_FIX_REPORT.md`	15건 이슈 수정 보고서

End of Security Audit Report